

A hálózati biztonság elvi alapjai: CIA-triász, Kerckhoffs-elv, Shannon-féle tökéletes titkosság.
Szimmetrikus vs aszimmetrikus kriptográfia szerepe, digitális aláírás és hash függvények.
Védelmi paradigmák evolúciója: perimeter → defense-in-depth → Zero Trust

A HÁLÓZATI BIZTONSÁG ELVI ALAPJAI

- az alapjait ezen elvek határozzák meg:
 - **CIA-triász**: alapkövetelmények
 - **Kerckhoffs-elv**: a titkosítás nem függhet a titkosító eljárás titokbántartásától, mivel az eljárást megismerheti az ellenfél
 - **Shannon-féle tökéletes titkosság**: titkos kulcs
- rendszer feltörés menete:
 - felderítés -> szkennelés (lista készítés) -> hozzáférés megszerzése
-> jogosultságok megemlése -> hozzáférés megtartása -> nyomok eltüntetése
- főbb kiberfenyegetések
 - malware (rosszindulatú szoftverek)
 - adathalászat (phishing)
- milyen biztonsági gondok lehetnek, “mit csinálhat egy rosszfiú”?
 - **adathalászat** (phishing)
 - adatok ellopása hamis email üzenetekkel, hamis weboldallal
 - közbeékelődéses támadás (man-in-the-middle)
 - **hallgatózhat**, azaz elkaphat egy üzenetet, csomagot
 - **beszúrhat új üzeneteket** a kommunikációba
 - **személyteleníthet**, azaz meghamisíthatja a forráscímet, vagy a csomag bármely mezőjét
 - **eltéríthet**, azaz a meglévő kapcsolatot kizárva átveheti a küldő vagy a fogadó oldalt
 - **szolgáltatás ellehetetlenítése**, azaz megakadályozza, hogy mások egy szolgáltatást igénybe vegyenek
 - pl: erőforrás túlterhelés
 - DoS (Denial of Service) támadás, azaz rengeteg csomag küldése
 - cél szolgáltatás kiválasztás
 - megfelelő gépekre kiosztani a munkát (botnet)
 - csomagok küldése a célgépnek
- hogyan támadhat?
 - kompromitált hitelesítő adatok
 - social engineering (közösségi manipuláció)
 - belső fenyegetések
 - szoftver sebezhetősége
- alaphoz az internet tervezésekor nem igazán gondoltak az ilyen jellegű biztonságra

- **célok**

- a hálózati biztonság alapvető problémáink megértése:
 - kriptográfia és használata a titkosságon túl
 - azonosítás
 - üzenet integritás
- biztonság a gyakorlatban:
 - tűzfalak és behatolás érzékelő rendszerek
 - biztonság az alkalmazási, szállítási, hálózati és adatkapcsolati rétegekben

- **titkosság**

- csak a küldőnek és a kijelölt fogadónak kellene tudnia az üzenet tartalmát megértenie
 - a küldő titkosítja az üzenetet
 - a fogadó visszafejti az üzenetet

- **szabályok**

- hozzáférési szabályok
 - azonosítja az erőforrásokat és a hozzáférést leíró szabályokat
- információ biztonsági szabályok
 - dolgozó milyen erőforrást (gép, szoftver) használhat
- információ védelmi szabályok
 - ki milyen szintű szenzitív információhoz fér hozzá és ezek hogyan legyenek tárolva, megsemmisítve vagy továbbítva
- jelszó szabályok
- email szabályok
- információ audit szabályok

CIA (Confidentiality, Integrity, and Availability)

- hálózati biztonság alapkövetelményeit írja le
- nem tökéletes, azaz annyira kell egy rendszernek biztonságosnak lennie, hogy a feltörésre fordított erőfeszítésnek jóval nagyobb legyen mint az elvárható haszon a feltörőnek
- **azonosítás (C - bizalmasság)**
 - a küldő és a fogadó is meg szeretne bizonyosodni a másikkal azonosságában, azaz biztos az-e akinek mondja magát
- **üzenet integritás (I - sértetlenség)**
 - a küldő és a fogadó szeretné tudni, hogy az üzenetet út közben senki nem módosította, vagy legalább is lehessen tudni róla, hogy változott-e az üzenet
- **hozzáférés és elérhetőség (A - rendelkezésre állás)**
 - a szolgáltatásoknak hozzáférhetőnek és elérhetőnek kell lennie folyamatosan vagy adott keretek között

Kriptográfia

- példák
 - transzpozíció
 - keverő titkosító (P-Box)
 - sorrend változtatás (pl: szavak betűinek sorrendje, vagy mondatok szavainak sorrendje)
 - helyettesítő titkosítók
 - cézár rejtjelzés
 - adott pozíció csúsztatása: pl. *A* betűt 3-al eltoljuk és *D*-t kapunk
 - monoalfabetikus: egy ÁBC-s helyettesítés
 - polyalfabetikus: több ÁBC-s helyettesítés
 - betűnként más-más (egymással összefüggő) ábécét, pontosabban egy ábécés helyettesítést használnak
 - hogy mikor melyik ábécé kerül sorra azt a kulcs határozza meg
 - RSA - asszimetrikus kulcsú titkosítás
- mikor jó egy titkosítás, azaz mikor biztonságos?
 - ha a titkosított szöveg alapján a kulcs nem meghatározható
 - ha a titkosított szöveg alapján nem tudjuk megtalálni a hozzátartozó nyílt szöveget és annak egyetlen karakterét sem
 - ha a titkosított szöveg alapján semmilyen használható információhoz nem jut hozzá az ellenfél
 - ha a titkosított szöveg alapján a nyílt szövegnek semmilyen transzformáltja sem állítható elő
- Titkosító eljárás
 - **Kerckhoff elve:** a titkosítás nem függhet a titkosító eljárás, azaz az algoritmus titkosságán, mivel az eljárást megismerheti az ellenfél
 - **Shannon maximája:** az ellenél ismeri a rendszert
 - feltételezi, hogy a támadó mindent tud, a kulcson kívül
 - ezen elvekből a kriptográfiai rendszereket így tervezzük:
 - nyílt rendszer, azaz nyílt algoritmusok, amik titkos kulcsokat használ
 - **a titkosításnak a kulcs titkosságán kell alapulnia**
 - az összezavarásra alapuló biztonság nem működik, ezért vannak nyílt algoritmusok
 - szakértői áttekintés és nyilvános vizsgálat
 - akkor biztonságos egy kriptografikus eljárás, ha adott erőforrással bíró ellenfél nem tudja visszafejteni
 - eljárás **(t , ϵ) biztonságos**, ha t futási idő alatt az ellenfelek ϵ -től kisebb eséllyel fejtik vissza a titkosított szöveget
 - napjainkban a titkosítási eljárások ereje a gyakorlati feltörhetetlenségen alapul, de elméletileg feltörhető
 - a feltörés sikere a számítási kapacitástól függ

- **Shannon-féle tökéletes titkosítás**

- a Shannon-féle kódolás lényege, hogy van egy titkos kulcs, amivel titkosítjuk az üzenetet (nyílt szöveget) és ez ad egy titkosított üzenetet, aminek dekódolásához ismernünk kell a titkos kulcsot
 - lehetetlen megmondani, hogy melyik a helyes kulcs, mert rentgeteg kombinációt ki kell próbálni
- tökéletes biztonság, egy olyan kódolt üzenetre utal amely nem ad információt az eredeti nyílt szövegre, hacsak nincs meg a titkos kulcsod, amivel az üzenet titkosítva lett
 - titkos kulcs ismerete nélkül nem dekódolható
- **egyszer használatos lap**
 - elméletileg feltörhetetlen titkosítási módszer
 - a gyakorlati kihívása, hogy a kulcs gyakran akkora mint az üzenet és magát a kulcsot biztonságosan kellene eljuttatni a másikfélnek
 - fontos, hogy ez felfedi, hogy a valódi üzenet mekkora és ebből következtetni azért lehet (oldalcsatorna-támadás)
 - nem közvetlen a kriptográfiát támadja, hanem máshol keres adatokat
 - pl: hang tömörítés esetén vannak szavak amik jobban tömöríthetők ezért mondjuk kitalálhatók a rövidségük alapján

- kulcs erősség

- gyakori támadások a titkosítás ellen:
 - brute force támadás
 - ismert nyílt szöveg támadás
 - választott titkosított szöveg támadás
 - oldalcsatorna támadás
 - közbeékelődéses (Man-in-the-Middle) támadás
- a kulchossz és a biztonság (támadás ellenállóképesség) között kapcsolat van
 - minden algoritmushoz más kulchossz ajánlott

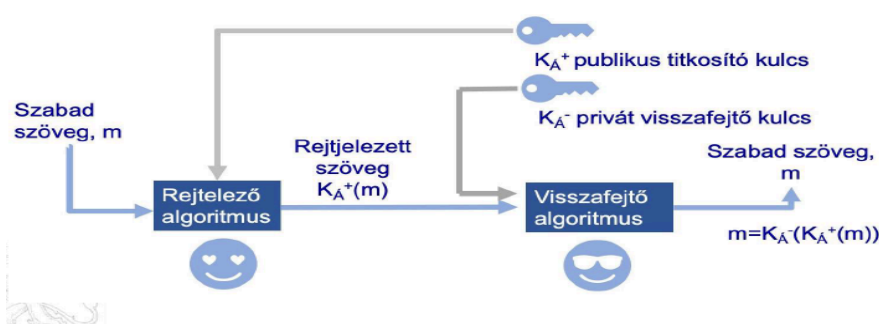
SZIMMETRIKUS ÉS ASSZIMMETRIKUS KRIPTOGRÁFIA SZEREPE, DIGITÁLIS ALÁÍRÁS ÉS HASH FÜGGVÉNYEK

Szimmetrikus kulcsú titkosítás

- lényege, hogy mindkét fél (küldő és a fogadó) is **ugyanazt a kulcsot használja**
 - csak egyetlen, megosztott kulcs van
- előnyei
 - gyors és hatékony, illetve alkalmas nagy adatmennyiségekhez
 - erős biztonságot ad ha megfelelően van implementálva és a kulcskezelés is jól van megoldva
 - alacsony számítási igény
- korlátai
 - kulcselosztás
 - rosszul skálázható nagy hálózatokban
 - hitelesítés hiánya
- kulcskezelési kihívások
 - biztonságosan hogyan osszák meg egymással a kulcsot
 - kulcsok biztonságos tárolása és védelme
 - kulcsrotáció és életciklus kezelés
- pl:
 - AES (Advanced Encryption Standard)
 - DES (Data Encryption Standard)
 - 3DES (Triple DES)
- gyakori felhasználási esetek:
 - fájl és lemeztitkosítás
 - adatbázis-titkosítás
 - biztonságos kommunikációs csatornák
- legjobb gyakorlatok, ha ilyet akarunk használni:
 - erős szabványosított algoritmusok használata pl: AES
 - nem sajátot írni
 - megfelelő kulcskezelés implementálása
 - kombinálás más biztonsági intézkedésekkel

Asszimmetrikus kulcsú titkosítás (nyilvános kulcsú titkosítás)

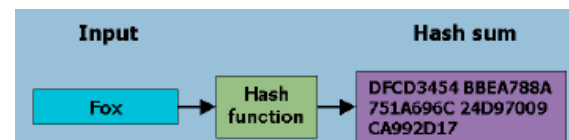
- a küldő és a fogadó nem ugyanazt a kulcsot használja
 - van egy **nyilvános titkosító kulcs**, ezt mindenki ismeri, szabadon terjeszthető
 - van egy **titkos visszafejtő kulcs**, ezt csak a fogadó ismeri



- előnyei
 - megoldja a kulcselosztás problémáját
 - a fogadónak van saját titkos kulcsa, a nyilvános kulccsal meg mindkét fél rendelkezik
 - lehetővé teszi a digitális aláírásokat
 - biztosítja a letagadhatatlanságot
- korlátai
 - lassabb és számításigényes
 - hosszabb kulcsokat igényel
 - bizonyos típusú támadásokra érzékeny (pl: közbeékelődéses támadás)
- példák
 - RSA (kitalálók neveinek kezdőbetűiből ered a név)
 - ECC (Eliptikus görbe kriptográfia)
 - DSA (digitális aláírás algoritmus)
- alkalmazási területek
 - biztonságos kulcscsere
 - digitális aláírások
 - biztonságos email (pl: PGP)

Hash (kivonat) függvények

- üzenet -> hashelő eljárás -> hashelt érték
 - fix kimeneti méret (hossz), a bemeneti mérettől függetlenül
 - egyirányúság (hashelt érték nem alakítható vissza a bementére)
 - determinisztikus (ugyanarra a bementre ugyanazt a kimenetet adja)
 - ütközésmentes, két különböző bemenet nem ad ki azonos hashelt értéket
- szerepük:
 - hatékonyság növelése
 - üzenet integritás
 - letagadhatatlanság
- gyakori hash függvények
 - MD5 (elavult)
 - legnépszerűbb volt
 - 128-bites kivonatot képez 4 lépésben
 - SHA-1 (elavult)
 - US szabvány
 - 160-bites üzenet kivonat
 - SHA-256, SHA-3
- biztonsági alkalmazások:
 - jelszó tárolás
 - adatintegritás
 - digitális aláírások
 - blokklánc

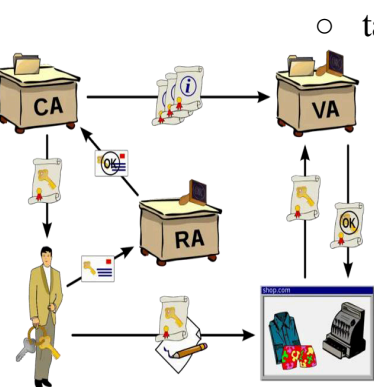


Digitális aláírás

- klasszikus aláírással egyenértékű kriptográfiai technológia
- lényege, hogy a küldő digitálisan aláírja az üzenetet, bizonyítva, hogy ő a létrehozója, tulajdonosa
 - a digitális aláírás csak egy adott üzenetre vonatkozik
- fontos, hogy ez ellenőrizhető, azaz nem hamisítható
 - a fogadó bizonyíthatja másnak is, hogy az üzenetet a küldő írta alá és azt is ellenőrizheti, hogy az üzenet változott-e
 - digitális aláírás csak akkor hamisítható, ha titkos, aláírásra használt kulcsot valaki megszerzi
- **digitális aláírás folyamata**
 - üzenet hashelése
 - hash titkosítása a saját privát kulccsal
 - a titkosított hash csatolása az üzenethez
- **ellenőrzési folyamat**
 - a fogadó fél hasheli a kapott üzenetet
 - visszafejti az aláírást a küldő nyilvános kulcsával
 - összehasonlítja a két hash-t (az üzenetekét)

Nyilvános kulcsú infrastruktúra (PKI)

- a hitelesítő hatóság egy adott entitáshoz (ember, forgalomirányító) köti a nyilvános kulcsot egy tanúsítvány segítségével
- **digitális tanúsítvány**
 - digitális aláírás vs digitális tanúsítvány
 - digitális aláírás = sima aláírás
 - csak egy üzenetet hitelesít (az élettartama egyszeri)
 - azt mutatja meg kiírta alá
 - digitális tanúsítvány = személyigazolvány
 - a küldő fél személyazonosságának igazolására jó
 - élettartalma akár 1-2 év, tehát hosszabb ideig érvényes
 - bizalmat épít
 - azt mutatja meg ki a gazdája a nyilvános kulcsnak
 - egy üzenethez általában mindkettőt küldjük
 - tartalma: **nyilvános kulcs**, azonosító információk, lejárat dátum
 - egy kiállított tanúsítvány tehát tartalmazza egy entitás nyilvános kulcsát, ráadásul úgy, hogy ezt a hitelesítő hatóság aláírja a saját privát kulcsával
 - életciklusa
 - kibocsátás (hitelesítő hatóság)
 - terjesztés (regisztrációs szervezet)
 - visszavonás (lejár a lejárat dátum vagy simán visszavonásra kerül)
 - megújítás (újra azonosítja magát)

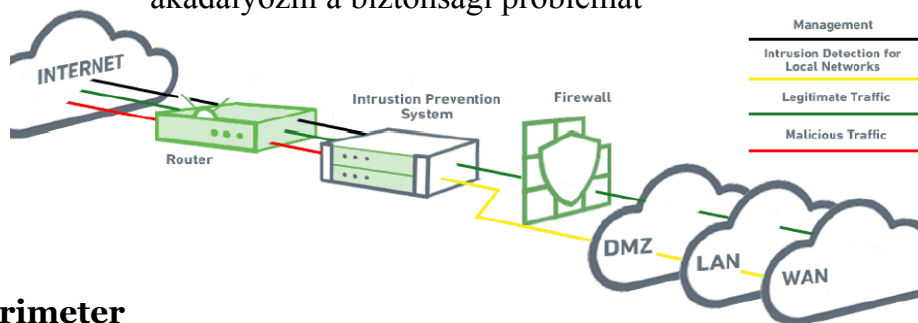


- tanúsítvány kiállításának menete:
 - az entitás bemutatja azonosságának bizonyítékait a **regisztrációs szervezetnek**, akik ezeket ellenőrzik
 - majd a **regisztrációs szervezet** leokézva tovább küldi az adatokat a **hitelesítő hatóságnak**, ami az adatok alapján elő állít egy **digitális tanúsítványt**, melyet a **hitelesítő hatóság** a saját privát kulcsával aláír
 - a **hitelesítő hatóság** visszaküldi az entitásnak a **digitális tanúsítványát**, mely az rögtön használni is tud
 - emelett elküldi az **ellenőrző hatóságnak** is a tanúsítványt
- tanúsítvány használata (példa)
 - a felhasználó vásárolni szeretne egy webshopban, ekkor a tranzakció során elküldi a **digitális tanúsítványát** a szervernek, hogy bizonyítsa kilétét és biztonságos csatornát építsen ki
 - mielőtt a webshop elfogadná a tanúsítványt, meg kell győződnie arról, hogy az még mindig érvényes-e (például nem vonták-e vissza korábban)
 - ezért elküldi a tanúsítványt az **ellenőrző hatóságnak**, aki ellenőrzi, hogy érvényes-e, ha érvényes egy OK-val válaszol
 - miután az **ellenőrző hatóság** visszaigazolta a tanúsítvány érvényességét, a webshop (vagy bármilyen szolgáltató) megbízik a kapcsolatban, és a biztonságos tranzakció (vásárlás) végbemehet
- tanúsítványok szerepe:
 - identitás ellenőrzés
 - nyilvános kulcs terjesztése
 - bizalom kialakítása (hogyan bizhat pl az oldalon stb)
- felhasználási területei
 - biztonságos böngészés (HTTPS)
 - biztonságos e-mail (S/MIME)
 - kód aláírás
- SSL/TLS kézfogás
 - Secure Sockets Layer (SSL) és Transport Layer Security (TLS)
 - menete
 - kliens üdvözlése
 - szerver üdvözlése
 - tanúsítvány csere
 - kulcscsere
 - biztonságos kommunikáció

VÉDELMI PARADIGMÁK EVOLÚCIÓJA: PERIMETER -> DEFENSE-IN-DEPTH -> ZERO TRUST

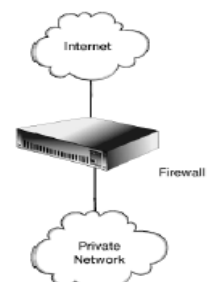
Védelmi megoldások és szabályok

- (talán) nincs tökéletes megoldás
- elvileg csak megfelelően beállított gépekre van szükség, de a szoftver és emberi mulasztások, stb, miatt mégis szükségesek különböző megoldások:
 - elosztott, jól koordinálható, több rétegű védelem
 - integrált, beépített megoldások (kapcsolók, forgalomirányítók, szerverek,...)
 - automatikus reakció
 - védelmi kerentrendszer:
 - védelem - védelmi rendszer
 - szabályozás - bizalom és identitás menedzsment
 - titkosítás - biztonságos kapcsolat
- megközelítési módok a problémák kezelésére
 - **reaktív**: ha bekövetkezik a probléma akkor kezeljük
 - **proaktív**: egy folyamatos megelőző tevékenység, mellyel meg próbáljuk akadályozni a biztonsági problémát



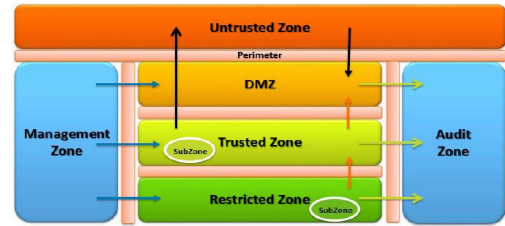
Perimeter

- annyit teszi ki, hogy a hálózatot két biztonsági övezetre, zónára kell osztani:
 - nem megbízható zóna (untrusted)
 - ez maga az internet innen érkeznek a potenciális támadások
 - megbízható zóna (trusted)
 - ez a belső hálózat (pl: céges hálózat)
- a **perimeter** ezen két zóna közötti határvonal, védelmi zóna
 - általában ez egy külső, határ tűzfal vagy VPN
- aki a perimeteren belül van az megbízható, aki kívül az nem
 - gyengesége, hogy ha egy támadó bejut (pl. egy ellopott / feltört jelszóval) akkor onnantól kezdve korlátok nélkül mozoghat a hálózaton belül
- **határ tűzfal architektúra**
 - egyszerű és olcsó
 - egy eszköz köti össze az összes hálózatot és erre az eszközre van telepítve a tűzfal összes funkciója
 - ez a fő gyengesége is



Defense-in-Depth (mélységi védelem)

- itt a megbízható zónát további biztonsági zónákra kell bontani
 - egy-egy ilyen zónának, övezetnek meg van a maga szabályrendszere
 - zónák közötti kommunikáció szigorúan szabályozott, jellemzően tűzfalak által
 - lehetnek olyan zónák is amik például csak a felügyeletért (Management) és a naplózásért (Audit) felelősek
 - a védelem része az is, hogy figyelünk, mert ezzel észrevehetünk furcsa viselkedéseket
 - a megbízható belső zóna mellé még egy Restricted (korlátozott) zóna is kerülhet, a legérzékenyebb adatoknak (pl: adatbázis, titkoskulcsok)
 - ide csak nagyon ellenőrzött módon a megbízható belső zónából lehet csatlakozni

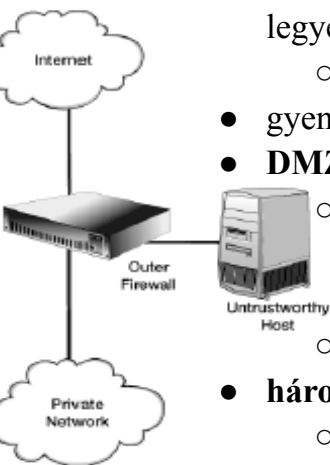


- logika mögöttes az, ha az egyik védelmi vonal el is esik, átjutnak rajta akkor is még legyen több mögöttes, hogy belül ne tudjon korlátok nélkül mozogni a támadó
 - lassítja a támadót

- gyengesége, hogy továbbra is fönny áll a belső bizalom fogalma

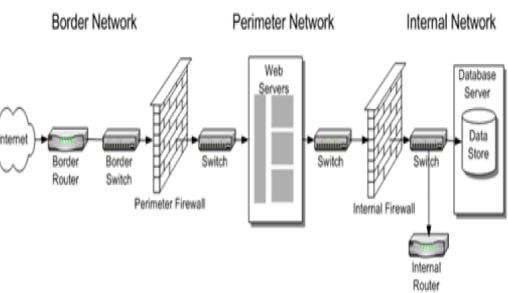
DMZ (deMilitarized zone) architektúra

- egy izolált környezetben futtat publikus (megbízhatatlan) szolgáltatásokat
 - eddig ezek a határ tűzfalon kívülre estek, most viszont a DMZ-be lesznek ami valamilyen szinten már védi őket
- nagyobb lesz ezzel a biztonság, a megbízhatóság



három zónás architektúra

- célja ugyanaz mint a sima DMZ architektúrának
- dupla tűzfal - célszerű különböző típusúakat választani
 - egy perem tűzfal

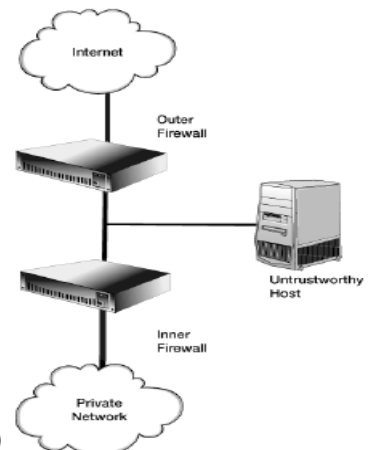


- véd az internetről érkező külső hatásoktól
 - jó esetben felfogja a támadásokat

- feladata a szervezet határain túli felhasználók kiszolgálása:
 - megbízható (távoli iroda)
 - félig megbízható (üzleti partnerek)
 - megbízhatatlan (publikus weboldal)

■ egy belső tűzfal

- a belső hálózathoz történő hozzáférést szabályozza
 - külső nem megbízható felhasználók elvileg soha nem léphetnek be a belső hálózatra
- pl: webszerver esetén a belső hálózattal nem az ismeretlen felhasználó, hanem a webszerver fog kommunikálni
- DMZ (deMilitarized zone)



Zero Trust (Zéró bizalom)

- a modern kor válasza a felhőszolgáltatásokra és a mobilitásra
- itt megszűnik a "belső hálózat" probléma fogalma
- lényege, hogy soha ne bízz senkiben, mindig ellenőrizz
 - minden kérést akár belső, akár külső hálózatról jön hitelesíteni (autentikálni) és autorizálni kell
- **mikroszegmentáció**
 - a hálózatot apró részekre bontják, így a fertőzött gép nem éri el a többi
- **legkisebb jogosultság**
 - mindenki csak ahhoz fér hozzá, amire neki szüksége van (kell a munkájához)
- **kontextusfüggő**
 - vizsgálja az eszköz állapotát, a helyszínt, az időpontot és a felhasználó viselkedését is
- gyengesége, a kompromitált fiókok és eszközök

Tűzfal típusok

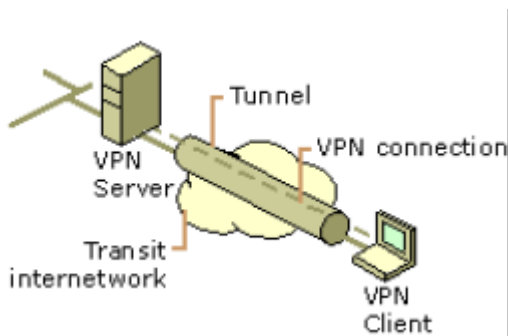
- **csomagszűrő**
 - forrás vagy cél IP cím/Port alapján szűr
 - gyors és kis erőforrás igény
 - 3. rétegben (hálózati)
- **NAT - Network Address Translation**
 - címfordítást végez: privát IP/port -> publikus
 - elrejt a belső címeket
- **kapcsolat szintű átjáró**
 - nem vizsgál meg minden csomagot, azaz ha kapcsolat felépült utána az adott kapcsolathoz tartozó csomagok mehetnek
 - 4. rétegben (szállítási)
 - jobb mint a sima csomagszűrés
- **állapottartó**
 - 3. és 4. rétegben működik (hálózati és szállítási réteg)
 - a kapcsolattartó és a NATos tűzfal kombinációja
 - minden kimenő csomag naplózva van az állapot táblába
 - forrás/cél IP cím/Port
 - a bemenő forgalomnál így ellenőrizhető
 - alapvető elvárás
- **proxy**
 - kliens - proxy - szerver (3 vagy több fél között folyik a kommunikáció)
 - titkosítatlan esetben a kliens nem látja közvetlenül azokat a csomagokat amelyeket a szerver küldött és fordítva
 - titkosított esetben a proxy ellenőrzi a fejléceket és ha minden jó csak akkor továbbítja
 - van sima, van forward (kliens oldal) és van reverse proxy (szerveroldalon) is

IDS

- behatolás érzékelés
 - viselkedés alapú érzékelés
- riasztás értékelése ma még többnyire manuális, ember végzi

VPN (Virtual Private Network)

- magánhálózat kiterjesztése publikus hálózat (internet) segítségével
 - akár egy kliens részére (pl: egy home officeből dolgozó embernek)
 - akár több kliens részére (pl: egy vidéki iroda)
- így ugyanolyan környezet érhető el mint például a munkahelyen
- az adatok IP csomagokba ágyazva közlekednek a publikus hálózaton (tunnel)
 - akár titkosítást is lehet alkalmazni



Virtuális magánhálózat (VPN)

